WELT 5 · HEUTE · ÜBERALL

Das Netz

Wem kannst du trauen, wenn jeder alles fälschen kann?



Die gefälschte Website

E-Mail: „Wichtiges Sicherheitsupdate für Ihr Chronoskop! Jetzt herunterladen.“

	offizielle Seite	Datei aus der E-Mail
Domain	`archiv.chronoskop.example`	`chronoskop-archiv.example`
Datei	`chronoskop-update-v7.zip`	`chronoskop-update-v7.zip`
SHA-256	`03a20cc0 … 0134dae7`	`03d0d355 … 8f2ad39e`
Schloss	🔒 Zertifikat für `archiv.chronoskop.example`	🔒 Zertifikat für `chronoskop-archiv.example`

Ist die Datei echt? Woran erkennt ihr das?

Warm-up

AUFTRAG | Einzelarbeit | 10 min

Lab → **Warm-up W5** – drei Karten, dann Kurzvergleich.

Doppelstunde	Karten	Themen
DS 14	WU-W5-01 · 10 · 12	Mini-Hash · Hybrid · Schlüsselanzahl
DS 15	WU-W5-02 · 04 · 11	Wer siegelt womit? · Schutzziele · Vigenère
DS 16	WU-W5-05 · 07 · 08	Zertifikat · TLS · Mallorys Trick

Was muss ein Fingerabdruck können?

Anforderung	Bedeutung
feste Länge	Hashwert immer gleich lang (SHA-256: 256 Bit = 64 Hexziffern)
effizient berechenbar	auch für große Dateien schnell
Einwegeigenschaft	zum Hashwert praktisch keine passende Nachricht findbar
Kollisionsresistenz	praktisch keine zwei Nachrichten mit gleichem Hashwert findbar
Lawineneffekt	ein Bit anders → etwa die Hälfte der Bits anders

Eine **Hashfunktion** macht aus einer beliebig langen Nachricht einen **Hashwert fester Länge**.

Lawineneffekt bei SHA-256

„heute“ →

```
b748a919 ad3e0a2c e7499df9
3f42e4a9 babab9c7 f28fff79
8b66b534 66b4bc7e
```

„heutf“ →

```
1751ffd9 a4d1d9b3 e14e3209
a9fe839e 516bf7a6 000e14cf
76b6f21e 79bd0dc3
```

Ein Buchstabe anders → **134 von 256 Bits** verschieden.

Falle P9 · Hash ist keine Verschlüsselung

Ein Hashwert dient zum **Prüfen** (Integrität), nicht zum **Geheimhalten**.

SO NICHT ✗

„Ich speichere nur den Hash meines Tagebuchs – dann ist es **verschlüsselt**.“

SO RICHTIG ✓

- kein Schlüssel
- nicht umkehrbar
- viele Nachrichten je Hashwert

heute: **SHA-256**, SHA-3 · gebrochen: **MD5, SHA-1**

Der KRYPTOS-Hash

$$h \leftarrow (3 \cdot h + w) \bmod 29$$

Start h = 0 · Nummerierung **A = 1 … Z = 26**

Buchstabe	n	e	b	e	l
Wert w	14	5	2	5	12
3 · h + w	14	47	56	86	96
h	14	18	27	28	**9**

KH(„nebel“) = **9** · Tipp: 29, 58 oder 87 abziehen

```
kryptosHash(text: Zeichenkette): Ganzzahl
h ← 0
für i von 0 bis Länge(text) − 1
    w ← ASCII-Wert(Zeichen an Position i von text) − 96
    h ← (3 · h + w) mod 29
gib h zurück
```

Kollision!

Fach (Hashwert)	4	9	11	22
Nachrichten	hafen, eis, zoo, bear	nebel, nebfi	anker, tor	**heute, morgen**

Nur **29** mögliche Hashwerte, aber unendlich viele Nachrichten → **Schubfachprinzip**: Unter 30 Nachrichten haben sicher zwei denselben Hash.

Jede Hashfunktion hat Kollisionen – gute machen sie **unauffindbar**.

Kollisionen bauen

$$KH = (9 \cdot h + 3 \cdot v + l) \bmod 29$$

v = vorletzter, l = letzter Buchstabe: **vorletzter +1, letzter −3** → 3 · 1 − 3 = 0, der Hash bleibt.

Zustände	1	2	3	4	5
nebel	14	18	27	28	**9**
nebfi	14	18	27	0	**9**

Folge: **keine Kollisionsresistenz**, **kein Lawineneffekt**, keine Einwegeigenschaft.

Prüfsummen

Summe $S(t) = (\Sigma\, w_i) \bmod 29$

Wort	S
rabe	18 + 1 + 2 + 5 = **26**
bear	2 + 5 + 1 + 18 = **26**

→ Vertauschung **unbemerkt** (permutationsinvariant)

gewichtet $G(t) = (\Sigma\, i \cdot w_i) \bmod$

Wort	G
rabe	46 → **17**
bear	87 → **0**

→ Vertauschung **bemerkt**

Auch der KRYPTOS-Hash bemerkt sie: KH(„rabe“) = 13, KH(„bear“) = 4.

Passwörter speichern

1. **Registrierung:** zufälliges Salz erzeugen

2. Hash(Salz + Passwort) und Salz speichern – **nie das Passwort**

3. **Login:** Salz + Eingabe hashen

4. mit dem gespeicherten Wert **vergleichen**

Konto	Salz	KH(Salz + Passwort)
Ole	qx	13
Kim	kz	11

Beide: Passwort „sonne“ – man sieht es nicht.

Praxis: **Argon2, bcrypt** – langsam mit Absicht

Level 5.1 · Fingerabdrücke

MERKE

Hashwert = Fingerabdruck fester Länge. Gute Hashfunktionen: einweg, kollisionsresistent, Lawineneffekt.

Kollisionen gibt es immer (Schubfach) – gute Hashfunktionen machen sie unauffindbar.

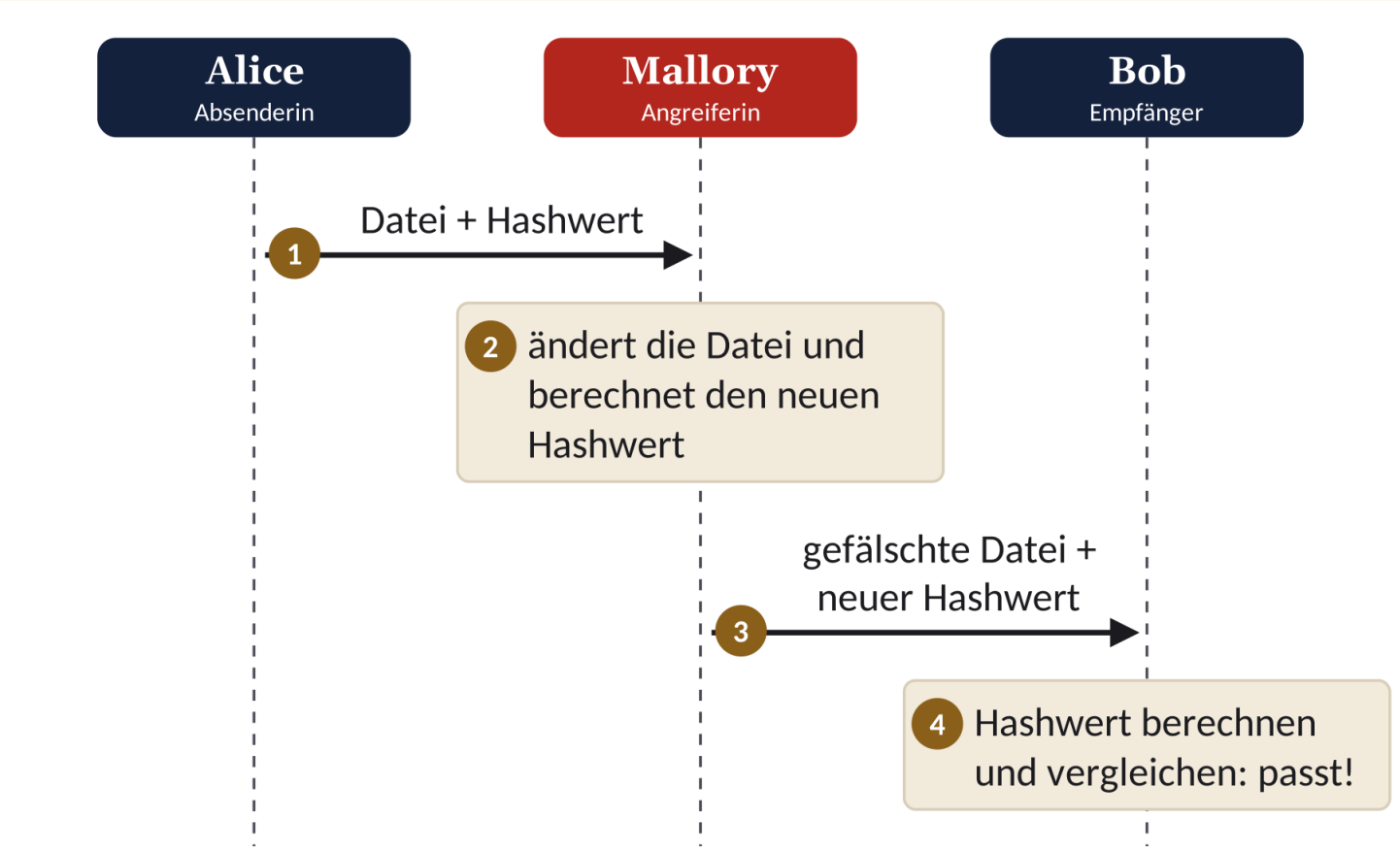
Hash ≠ Verschlüsselung. Passwörter nur **gesalzen gehasht** speichern.



Das Siegel

DS 15 · digitale Signatur, Schutzziele, signieren und verschlüsseln

Mallory rechnet mit

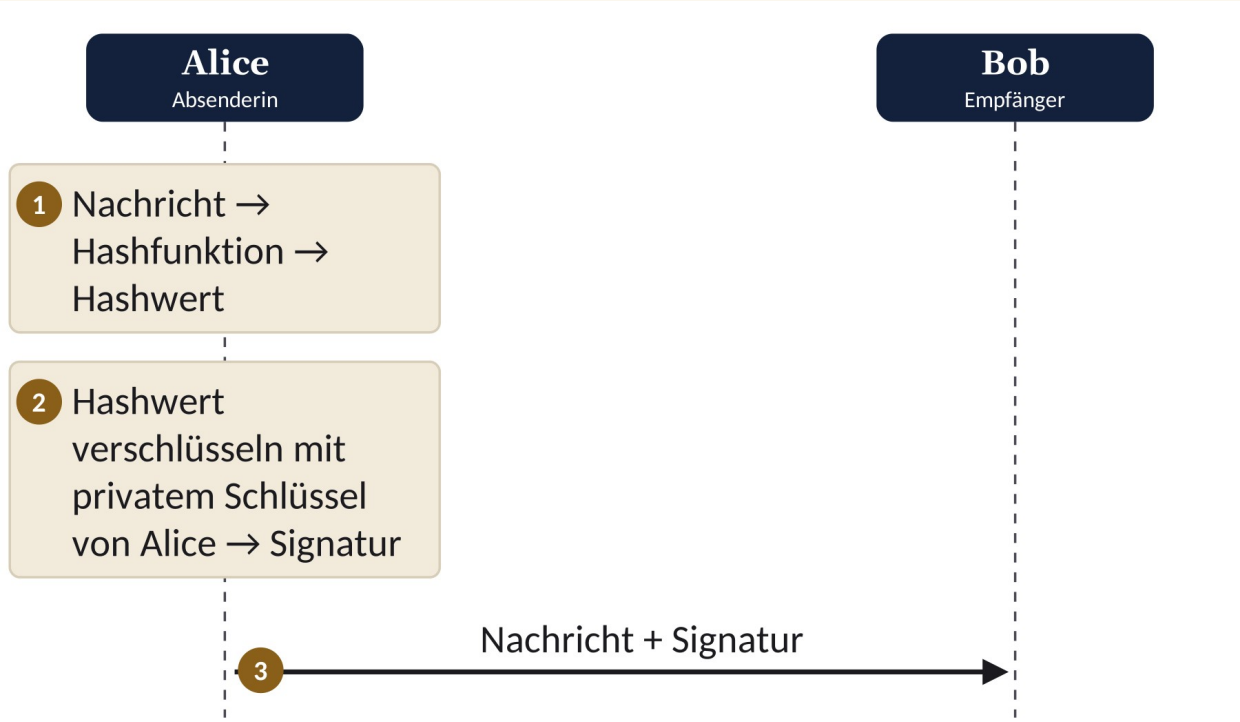


Bob vergleicht – **alles passt**.

Der mitgeschickte Hashwert schützt nur gegen **zufällige** Fehler.

Was fehlt?

Signatur erstellen

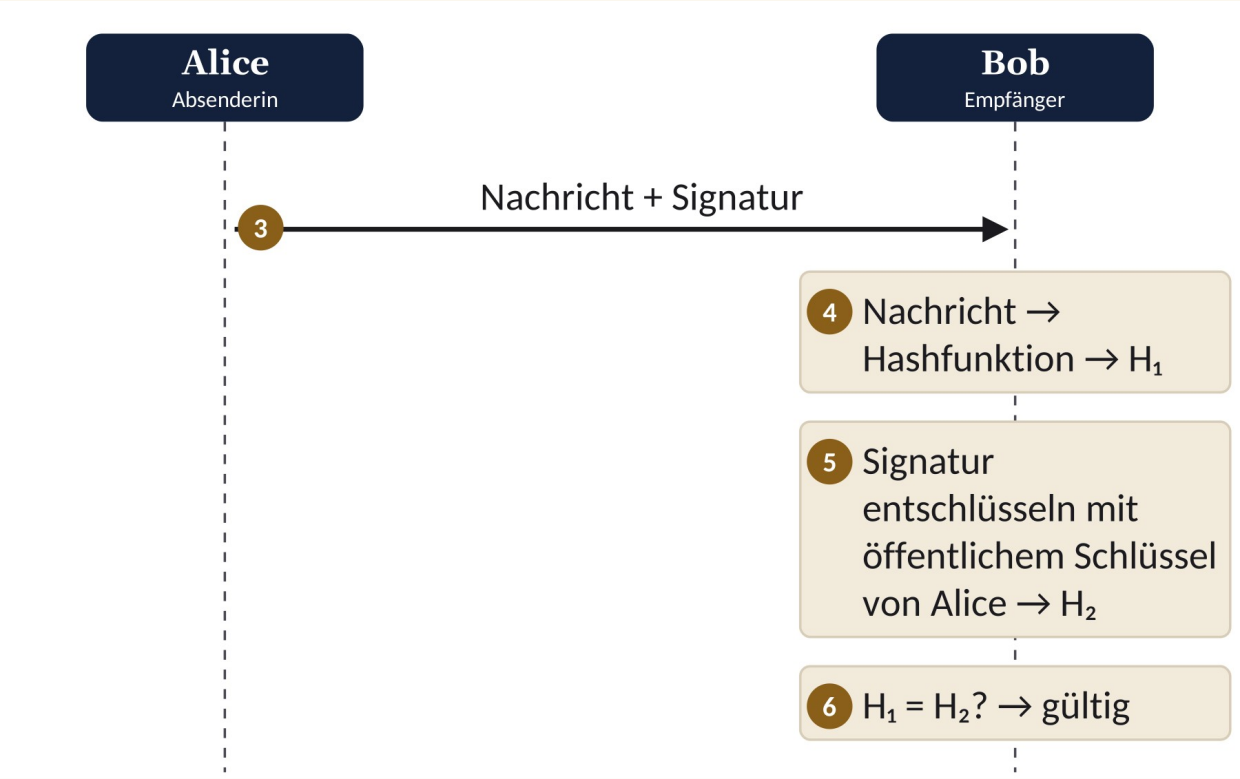


1. Hashwert der Nachricht berechnen

2. Hashwert mit **Alices privatem Schlüssel** verschlüsseln = **Signatur**

3. Nachricht + Signatur senden

Signatur prüfen



4 Bob: Hashwert H_1 der **empfangenen** Nachricht

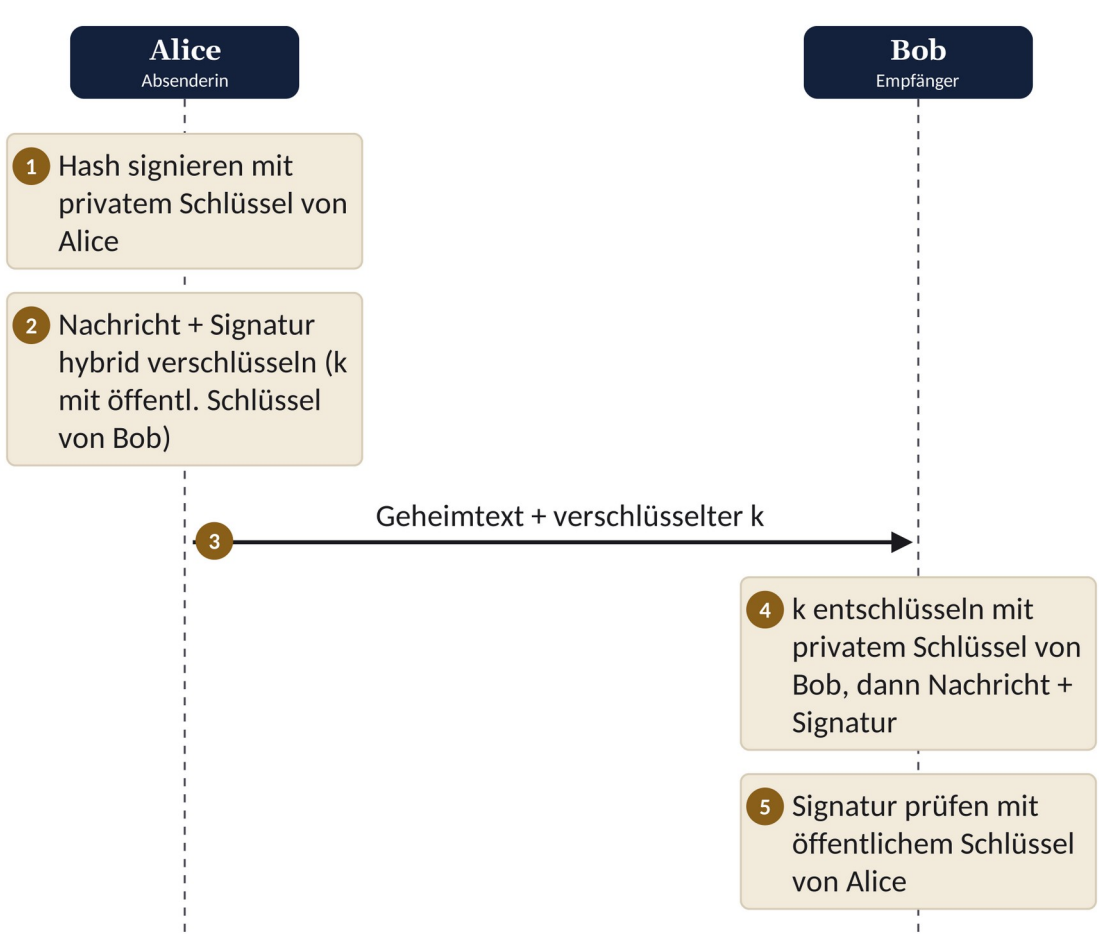
5 Signatur mit **Alices öffentlichem Schlüssel** entschlüsseln → H_2

6 **$H_1 = H_2$?** gleich → gültig, sonst ungültig

Schutzziele

Schutzziel	Bedeutung	durch Signatur?
Vertraulichkeit	nur Befugte können lesen	✕ – nur durch Verschlüsselung
Integrität	unverändert	✓
Authentizität	echter Absender	✓
Verbindlichkeit	nicht abstreitbar	✓

Signieren und verschlüsseln



Jedes Schlüsselpaar hat genau eine Aufgabe:

- Alices Paar → **Signatur**
- Bobs Paar → **Vertraulichkeit**

Bob macht alles in **umgekehrter Reihenfolge** rückgängig (P3).

Zwei Euro oder tausend?

Nachricht	KH	Signatur	Bob prüft
Alice: „ueberweise zwei euro“	18	s von Alice	gültig
Mallory: „ueberweise tausend euro“	18	**dieselbe** s	**gültig!**

Mallory braucht Alices privaten Schlüssel **nicht** – die alte Signatur passt zum gleichen Hashwert.

Eine Signatur ist nur so stark wie die Kollisionsresistenz der Hashfunktion.

Falle P9 · Schlüsselrollen

Signatur → Schlüssel der **Absenderin** · Vertraulichkeit → Schlüssel des **Empfängers**

SO NICHT ×

- „Alice signiert mit Bobs öffentlichem Schlüssel.“
- „Bob prüft, indem er die Signatur entschlüsselt.“

SO RICHTIG ✓

- Alice signiert mit **ihrem privaten** Schlüssel.
- Bob entschlüsselt **und vergleicht** H_1 mit H_2.

Level 5.2 · Das Siegel

MERKE

Signieren: Hashwert mit dem **privaten** Schlüssel der Absenderin verschlüsseln.

Prüfen: Hash selbst berechnen, Signatur mit ihrem **öffentlichen** Schlüssel entschlüsseln, **vergleichen**.

Signatur → Integrität, Authentizität, Verbindlichkeit. **Vertraulichkeit nur durch Verschlüsselung.**



Mallory im Netz

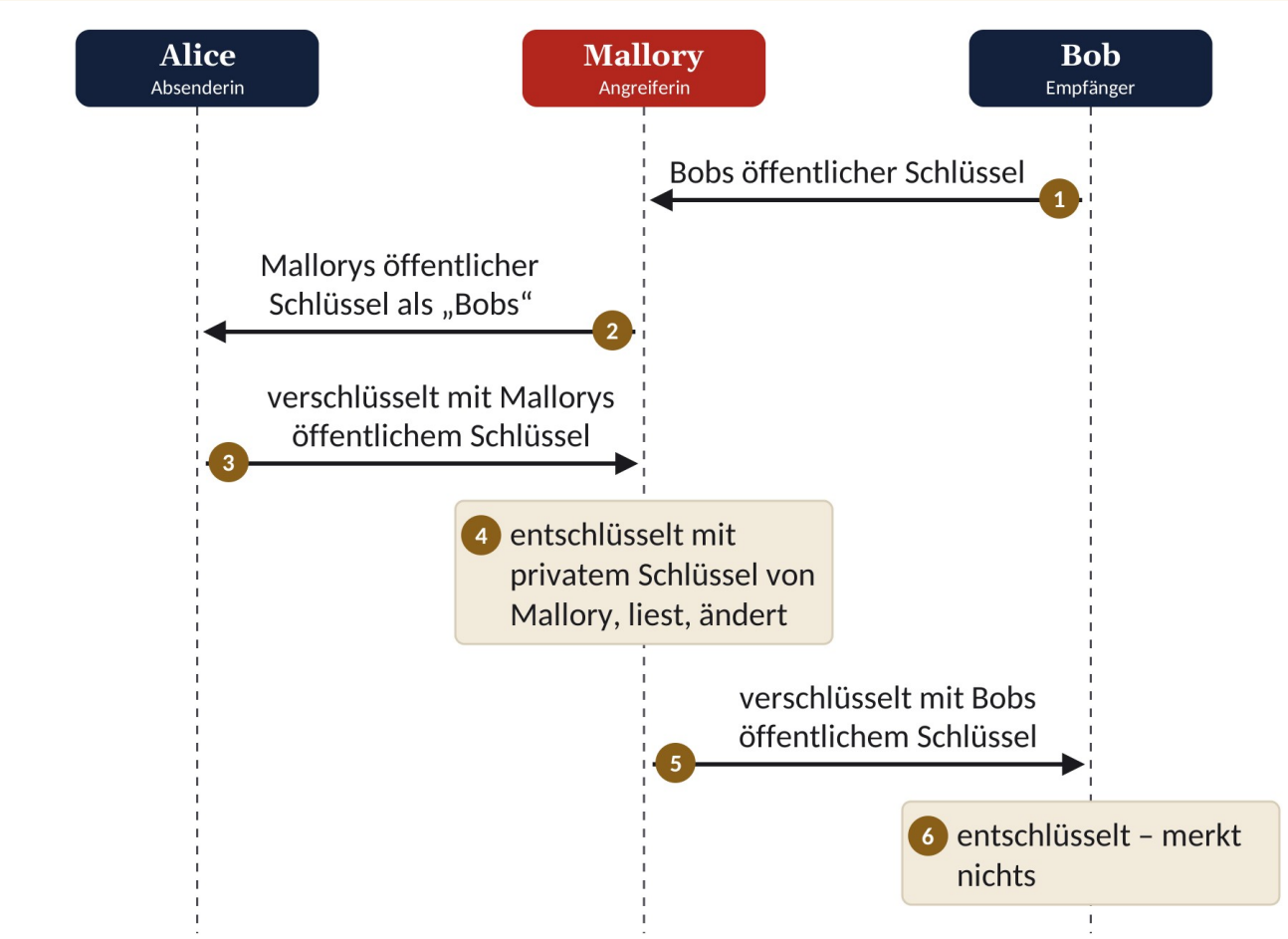
DS 16 · Man-in-the-Middle, Zertifikate, TLS, Datenschutz

Funkraum: Mallory im Netz

Rolle	Aufgabe
Alice-Teams	senden einen geheimen Auftrag
Bob-Teams	führen den Auftrag aus
Mallory-Team	Postamt – sitzt zwischen allen
Trent	Lehrkraft – siegelt Schlüssel

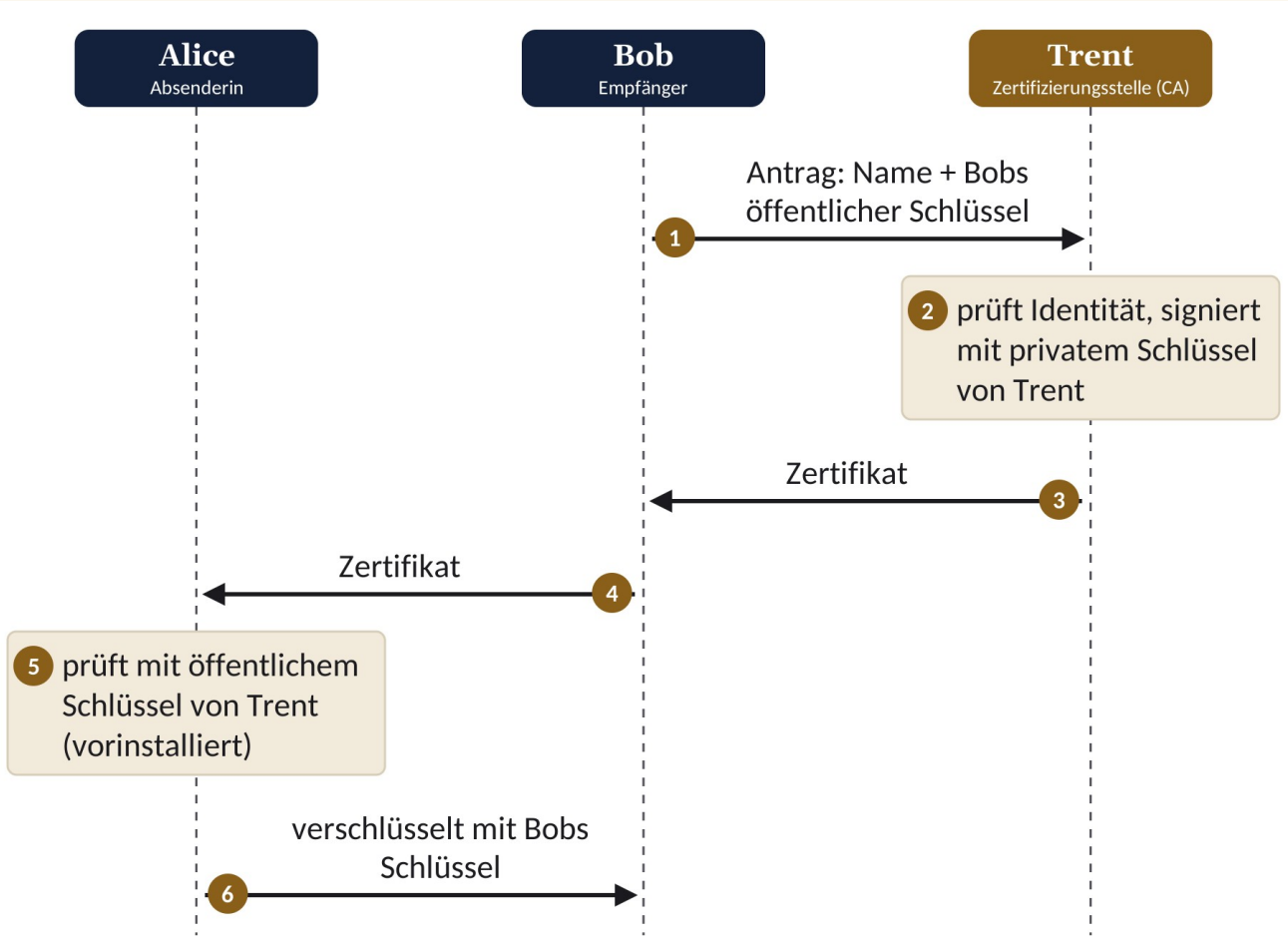
Phase 1: ohne Zertifikate · **Phase 2:** Trent siegelt Schlüssel

Was ist passiert?



- Mallory hat **kein Verfahren** gebrochen – sie hat Schlüssel **vertauscht**.
- gebrochen: Vertraulichkeit, Integrität, Authentizität
- Rettung: Eine **dritte Stelle** bestätigt, wem ein Schlüssel gehört.

Trent siegelt Bobs Schlüssel



Zertifikat = Name + öffentlicher Schlüssel + Gültigkeit, **signiert von der CA**.

Alice prüft mit **Trents öffentlichem Schlüssel** – der ist vorinstalliert.

Das Zertifikat

Inhaber	`bank-chronopolis.example`
öffentl. Schlüssel	RSA 2048 Bit, `30 82 01 0A …`
Aussteller	Chronopolis CA
gültig	01.09.2026 – 15.03.2027
Signatur der CA	Hashwert aller Angaben, verschlüsselt mit dem privaten Schlüssel der CA

Prüfung im Browser:

1. Signatur mit dem **öffentlichen Schlüssel der CA**
2. Name = aufgerufene Domain?
3. heute gültig?
4. nicht widerrufen?

Kette und Vertrauensanker

Trent Root CA	→	**Chronopolis CA**	→	`bank-chronopolis.example`
Wurzelzertifikat · im Browser **vorinstalliert**	signiert	Zwischenzertifikat	signiert	Serverzertifikat

- Ein Zertifikat bestätigt, **wem** der Schlüssel gehört – nicht, dass die Seite harmlos ist (P9).

- Alternative ohne zentrale CA: **Web of Trust** (z. B. OpenPGP).

TLS im Überblick

	Schritt	Verfahren
1	Browser: Hallo + unterstützte Verfahren	–
2	Server schickt sein Zertifikat (mit Kette)	–
3	Prüfung bis zum Vertrauensanker, Name, Gültigkeit	Signaturen prüfen
4	Sitzungsschlüssel vereinbaren	**asymmetrisch**
5	alle Daten verschlüsseln	**symmetrisch** (z. B. AES)

TLS = Zertifikatsprüfung + Hybridverfahren

Datenschutz: die DSGVO

Grundsatz (Art. 5 DSGVO)	Kurzform
Rechtmäßigkeit, Treu und Glauben, Transparenz	Rechtsgrundlage, nachvollziehbar
Zweckbindung	nur für festgelegte Zwecke
Datenminimierung	nur so viel wie nötig
Richtigkeit	falsche Daten berichtigen
Speicherbegrenzung	nur so lange wie nötig
Integrität und Vertraulichkeit	Verschlüsselung, Zugriffsschutz, Passwort-Hashing
Rechenschaftspflicht	Einhaltung nachweisen

Recht auf **informationelle Selbstbestimmung** (BVerfG 1983) · DSGVO seit 25. Mai 2018

Scannen vor dem Verschlüsseln?

Argumente dafür

- Schutz von Opfern schwerer Straftaten
- Ermittlungen dürfen nicht durch Technik verschwinden
- Verantwortung der Anbieter

Argumente dagegen

- anlassloses Durchsuchen aller Nachrichten
- Fehlalarme treffen Unschuldige
- Missbrauch der Prüffunktion
- Vertraulichkeit untergraben

Erörtern heißt: beide Seiten abwägen, **eigenes begründetes Urteil**.

Boss: Das Siegel der Stadt

AUFTRAG | Einzelarbeit | 25 min

Lab → Welt 5 → **Boss** · ohne Werkzeuge

Mallory will das Siegel der Stadt fälschen. Ab **50 %** gehört das Artefakt **„Siegel“** dir.

Ausblick: Welt 6 – die Zeitmaschine und Eves eigene Chiffre.